

CYBER SECURITY INTERNSHIP

Technical Report

# Man-in-the-Middle (MITM) Explainer

*Understanding How the Web Works and How Secure Communication Defends Against  
Interception*

Submitted by

**Muqaddis Sanobar**

Registration No: Mtech-CS26020

Task Title: Man-in-the-Middle (MITM) Explainer

Topic: How the Web Works

Cyber Security Internship Program — 2026

## Table of Contents

|                                                         |    |
|---------------------------------------------------------|----|
| Table of Contents .....                                 | 2  |
| 1. Introduction.....                                    | 3  |
| 2. What is a Man-in-the-Middle Attack? .....            | 3  |
| 3. How MITM Works Conceptually .....                    | 3  |
| 4. Common Situations Where MITM Attacks May Occur ..... | 4  |
| 5. Types of MITM Attacks (Overview Only).....           | 5  |
| 6. Risks and Impacts of MITM Attacks.....               | 5  |
| 7. How HTTPS Works.....                                 | 6  |
| 8. SSL/TLS Certificates .....                           | 7  |
| 9. Encryption During Communication .....                | 7  |
| 10. Certificate Validation .....                        | 8  |
| 11. Why HTTPS Prevents MITM Attacks.....                | 8  |
| 12. HTTP vs HTTPS: Comparison Table .....               | 9  |
| 13. Best Practices for Staying Protected.....           | 10 |
| 14. Real-World Examples (Educational Only).....         | 10 |
| 15. Key Takeaways .....                                 | 11 |
| 16. Conclusion .....                                    | 11 |
| 17. References .....                                    | 12 |

## 1. Introduction

---

Every time a website is opened, a message is sent and a reply comes back within a fraction of a second. Most people never stop to think about what happens in between. In reality, that short journey passes through several routers, service providers, and sometimes public networks before it reaches its destination. If that path is not protected, someone else could quietly sit in the middle of the conversation, reading or even changing the information without either side realising it.

This report was prepared as part of a cyber security internship task. Its purpose is to explain, in plain and simple language, what a Man-in-the-Middle (MITM) attack is, why it is possible, and how a security feature called HTTPS was designed specifically to close this gap. The report is written for someone who is new to cyber security and does not assume any prior technical background. No attack instructions, tools, or exploitation steps are included anywhere in this document; the focus is entirely on understanding the concept from a defensive and educational point of view.

## 2. What is a Man-in-the-Middle Attack?

---

A Man-in-the-Middle attack happens when an unauthorised third party secretly places itself between two devices that believe they are communicating directly with each other. Both sides continue talking as usual, unaware that their messages are passing through an extra, unwelcome stop along the way.

A simple way to picture this is to imagine two people passing folded notes to each other through a classmate who has agreed to act as a messenger. If that classmate quietly opens the notes, reads them, and even changes a word or two before passing them on, neither of the original two people would notice anything wrong unless they later compared what was written with what was received. A MITM attack works on the same basic idea, except the "notes" are pieces of digital data such as login details, messages, or payment information.

## 3. How MITM Works Conceptually

---

To understand MITM conceptually, it helps to first look at how communication is supposed to happen between two trusted parties, such as a laptop and a website's server.

#### Normal Communication (No Interception)

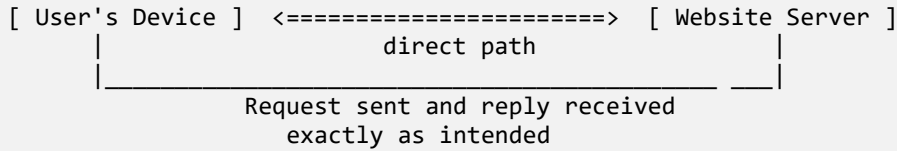


Figure 1: Normal communication travels directly between the two intended parties.

In a MITM situation, an attacker manages to insert their own system into that same path, without either party being told about it. The two original parties still believe they are talking to each other directly.

#### MITM Communication (Intercepted Path)

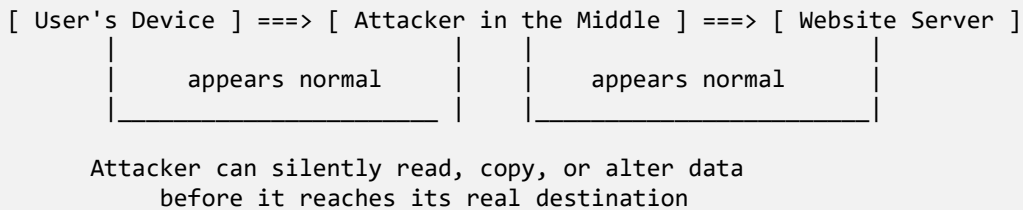


Figure 2: An attacker secretly positioned between the user and the server.

This positioning can happen conceptually in a few different ways, such as when a device connects to a network that is not what it claims to be, or when the system responsible for translating website names into addresses is manipulated. In every case, the underlying idea is the same: trust is placed in a path that has quietly been rerouted.

## 4. Common Situations Where MITM Attacks May Occur

MITM attacks are more likely in situations where the communication path is not fully controlled or verified by the user. Some common examples include:

- **Public Wi-Fi networks:** Airports, cafes, and hotels often provide open networks that do not require a password, making it easier for an unverified device to observe traffic on the same network.
- **Insecure or unencrypted websites:** Websites that still use plain HTTP instead of HTTPS transmit data as readable text, which can be intercepted without any special effort.

- Compromised or spoofed network hardware: A router or access point that has been altered, or a fake one set up to imitate a genuine network, can redirect traffic without users being aware.
- Outdated software and operating systems: Devices that have not been updated may be missing security patches that were specifically released to close known interception risks.
- Phishing links leading to fake versions of real sites: Sometimes the interception happens not on the network but through a convincing fake webpage that quietly forwards data to the real one.

## 5. Types of MITM Attacks (Overview Only)

There are several recognised categories of MITM attacks discussed in cyber security literature. This section gives only a brief, conceptual overview of each so the underlying idea is clear; it does not describe how any of them are carried out.

| Type                | Simple Description                                                                                                     |
|---------------------|------------------------------------------------------------------------------------------------------------------------|
| Wi-Fi Eavesdropping | Attacker positions themselves on an insecure or fake wireless network to observe traffic passing through it.           |
| DNS Spoofing        | The domain name system is tricked so a device is directed toward an incorrect destination instead of the real website. |
| Session Hijacking   | An ongoing, already-authenticated session between a user and a service is taken over without the user's knowledge.     |
| Email Hijacking     | Communication over email is silently observed or altered, often to redirect financial instructions.                    |
| SSL Stripping       | A secure HTTPS connection is downgraded to an unencrypted HTTP connection without the user noticing.                   |
| ARP Spoofing        | Address mapping on a local network is manipulated so traffic is misdirected through the attacker's device.             |

It is worth noting that this list is not exhaustive, and new variations continue to be documented as network technology evolves. The common thread across all of them remains the same: an attacker gains an unauthorised position along a communication path.

## 6. Risks and Impacts of MITM Attacks

The consequences of a successful MITM attack can range from minor inconvenience to serious, lasting harm, depending on what kind of data is exposed. Some of the most significant impacts include:

- Theft of login credentials, allowing unauthorised access to personal or organisational accounts.
- Exposure of financial information, such as card details or banking session data.
- Loss of confidential business communication, which can affect an organisation's reputation and legal standing.
- Manipulation of data in transit, where the attacker does not just read but actually changes information such as payment amounts or instructions.
- Erosion of user trust in a service once an interception incident becomes known publicly.

Because MITM attacks are often silent, victims may not realise anything happened until the stolen information is misused later, which makes early prevention far more valuable than after-the-fact recovery.

## 7. How HTTPS Works

HTTPS stands for HyperText Transfer Protocol Secure. It is the secure version of the HTTP protocol that browsers and servers use to exchange information. HTTPS does not change what data is sent; it changes how that data is protected while it travels.

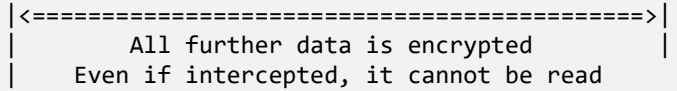
When a browser connects to a website using HTTPS, both sides perform a short introduction process, often called a handshake, before any actual webpage data is exchanged. During this handshake, the browser and the server agree on how they will encrypt the rest of the conversation, and the server proves its identity using a certificate, which is explained further in the next section.

### HTTPS Secure Communication

```

[ User's Browser ]           [ Website Server ]
| 1. Hello + supported encryption |
|----->|
| 2. Certificate + server's public key |
|<-----|
| 3. Certificate checked against trusted CA |
| 4. Shared secret key agreed securely |

```



|<----->|  
| All further data is encrypted |  
| Even if intercepted, it cannot be read |

Figure 3: The HTTPS handshake establishes trust and encryption before real data is sent.

Once this handshake is complete, every piece of information exchanged, such as login details, form entries, or page content, is wrapped in encryption. Even if someone manages to capture this data while it is travelling across the network, it would appear as meaningless scrambled text without the correct key to unlock it.

## 8. SSL/TLS Certificates

SSL (Secure Sockets Layer) was the original technology used to secure web traffic, and it has since been replaced by its more modern and secure successor, TLS (Transport Layer Security). The term SSL is still used casually in everyday conversation, but almost all secure websites today actually rely on TLS.

A certificate is a small digital file issued to a website by a trusted organisation known as a Certificate Authority (CA). This file contains information such as the website's domain name, its public key, and the identity of the authority that issued it. It works much like an identification card: it does not just claim who the website is, it is backed by a recognised authority that vouches for that claim.

- Domain Validation (DV): Confirms that the applicant genuinely controls the domain name; this is the most common and quickest type.
- Organisation Validation (OV): Includes an additional check confirming the identity of the organisation behind the website.
- Extended Validation (EV): Involves the most thorough identity checks, typically used by banks and large institutions.

## 9. Encryption During Communication

Encryption is the process of converting readable information into a scrambled format that can only be turned back into its original form by someone holding the correct key. HTTPS uses a combination of two encryption approaches to balance both security and speed.

First, during the handshake, a method called asymmetric encryption is used. This involves a pair of mathematically linked keys, a public key that can be shared openly and a private key that is kept secret by the server. This pair is used only long enough to safely agree on a temporary shared secret.

Once that shared secret is established, the rest of the session switches to symmetric encryption, where both sides use the same key to lock and unlock the data. Symmetric encryption is much faster, which makes it suitable for the large amount of data exchanged while browsing a website.

## 10. Certificate Validation

---

Certificate validation is the step where the browser checks whether the certificate presented by a website should actually be trusted. This process happens automatically and within moments, but it involves several careful checks:

- Confirming the certificate was issued by a Certificate Authority that the browser already trusts.
- Checking that the certificate has not expired and is currently valid.
- Verifying that the domain name listed on the certificate matches the website actually being visited.
- Making sure the certificate has not been revoked or reported as compromised by its issuing authority.

If any of these checks fail, the browser does not silently continue. Instead, it displays a clear warning to the user, which is one of the most important built-in defences against interception attempts.

## 11. Why HTTPS Prevents MITM Attacks

---

HTTPS was designed with the MITM problem specifically in mind, and it addresses it in three complementary ways. Understanding these together explains why HTTPS is such an effective defence.

- Confidentiality through encryption: Even if an attacker manages to sit along the communication path, the data they capture is unreadable without the session's unique key.



- Authentication through certificates: The certificate check confirms that the browser is genuinely talking to the real server and not an imposter pretending to be it.
- Integrity through tamper detection: HTTPS includes checks that reveal if data has been altered during transit, so any modification attempt causes the connection to fail rather than pass through unnoticed.

Because an attacker positioned in the middle cannot produce a valid certificate for a domain they do not own, and cannot decrypt traffic without the correct key, HTTPS effectively removes the silent advantage that a MITM attacker depends on.

## 12. HTTP vs HTTPS: Comparison Table

The table below summarises the core differences between the older, unprotected HTTP protocol and the modern, secure HTTPS protocol.

| Feature              | HTTP                                              | HTTPS                                                  |
|----------------------|---------------------------------------------------|--------------------------------------------------------|
| Full Form            | HyperText Transfer Protocol                       | HyperText Transfer Protocol Secure                     |
| Default Port         | 80                                                | 443                                                    |
| Data Encryption      | No encryption; data sent as plain text            | Data encrypted using SSL/TLS                           |
| Data Integrity       | Data can be modified in transit without detection | Any tampering is detected and connection fails         |
| Authentication       | No verification of server identity                | Server identity verified using a digital certificate   |
| Protection from MITM | Vulnerable, attacker can read or alter traffic    | Strongly resistant, traffic is unreadable to attackers |
| Browser Indication   | "Not Secure" warning shown                        | Padlock icon shown in address bar                      |
| SEO / Trust Impact   | Ranked lower, seen as less trustworthy            | Preferred by browsers and search engines               |
| Typical Use Today    | Rarely used for real websites                     | Standard for almost all modern websites                |

### 13. Best Practices for Staying Protected

---

While HTTPS forms the technical backbone of secure browsing, everyday habits also play an important role in reducing the risk of MITM exposure. Some widely recommended practices include:

- Always check for the padlock icon and "https://" before entering sensitive information on a website.
- Avoid logging into banking or email accounts while connected to open public Wi-Fi networks.
- Keep operating systems, browsers, and applications updated to receive the latest security patches.
- Use a trusted Virtual Private Network (VPN) when connecting through networks that cannot be fully trusted.
- Pay attention to browser security warnings instead of dismissing them automatically.
- Enable multi-factor authentication wherever possible, so a stolen password alone is not enough to gain access.
- Verify website URLs carefully, since attackers sometimes use addresses that look almost identical to genuine ones.

### 14. Real-World Examples (Educational Only)

---

Over the years, several publicly documented incidents have highlighted how serious the impact of interception-style attacks can be when secure protocols are missing or misconfigured. These examples are mentioned here purely for educational awareness, with no technical detail on how they were carried out.

- In the mid-2010s, several public reports described how attackers exploited unsecured public Wi-Fi hotspots in cafes and airports to intercept unencrypted login sessions, which contributed to widespread industry pressure to adopt HTTPS everywhere.
- Security researchers have repeatedly demonstrated, in controlled and disclosed research settings, how outdated or misconfigured SSL/TLS implementations on some websites left users exposed until patches were released.

- Awareness campaigns by browser vendors, including the shift toward marking all HTTP sites as "Not Secure," were a direct response to years of documented interception risk affecting everyday users.

These examples reinforce why organisations such as browser vendors and standards bodies have pushed strongly toward encrypted-by-default communication across the modern web.

## 15. Key Takeaways

---

- A MITM attack occurs when an unauthorised party secretly positions itself between two communicating devices.
- Public Wi-Fi and unencrypted websites are among the most common environments where this risk arises.
- HTTPS defends against MITM through a combination of encryption, certificate-based authentication, and tamper detection.
- SSL/TLS certificates issued by trusted Certificate Authorities confirm that a website's identity is genuine.
- Good personal habits, such as checking for the padlock icon and avoiding sensitive logins on public networks, remain essential even with HTTPS in place.
- Understanding MITM conceptually helps build the foundation for deeper study into network security and cryptography.

## 16. Conclusion

---

Man-in-the-Middle attacks represent one of the clearest examples of why trust cannot simply be assumed on a shared network. As this report has shown, the underlying idea is not overly complex: it is about someone gaining an unnoticed position along a path that two parties believe is private and direct. What makes the topic important for a cyber security student is not the attack itself, but the elegant way HTTPS, along with SSL/TLS certificates and encryption, was engineered to close that gap through verified identity and unreadable data.

Working through this assignment helped connect several ideas that are often taught separately, such as encryption, certificates, and browser behaviour, into a single, practical picture of how secure browsing actually functions in daily life. It also reinforced that technology alone is not a

complete solution; safe habits from the user's side remain just as necessary. This balance between strong protocol design and informed user behaviour is likely to remain a central theme throughout the rest of this internship and any future work in cyber security.

## 17. References

---

Cisco. (2023). What Is a Man-in-the-Middle (MITM) Attack? Cisco Systems. <https://www.cisco.com/c/en/us/products/security/what-is-a-man-in-the-middle-attack.html>

Cloudflare. (n.d.). What is a man-in-the-middle attack? Cloudflare Learning Center. <https://www.cloudflare.com/learning/security/threats/man-in-the-middle-attack/>

Cloudflare. (n.d.). What is SSL? Cloudflare Learning Center. <https://www.cloudflare.com/learning/ssl/what-is-ssl/>

Google. (n.d.). Why HTTPS matters. Google Web.dev. <https://web.dev/articles/why-https-matters>

Microsoft Learn. (2023). Transport Layer Security (TLS) best practices. Microsoft. <https://learn.microsoft.com/en-us/security/engineering/solving-tls1-problem>

Mozilla. (n.d.). TLS (Transport Layer Security). MDN Web Docs. <https://developer.mozilla.org/en-US/docs/Glossary/TLS>

Mozilla. (n.d.). What is HTTPS? MDN Web Docs. <https://developer.mozilla.org/en-US/docs/Glossary/HTTPS>

National Institute of Standards and Technology. (2019). Guidelines for the Selection, Configuration, and Use of Transport Layer Security (TLS) Implementations (NIST Special Publication 800-52 Rev. 2). U.S. Department of Commerce. <https://csrc.nist.gov/publications/detail/sp/800-52/rev-2/final>

OWASP Foundation. (n.d.). Man-in-the-middle attack. OWASP Community Pages.  
[https://owasp.org/www-community/attacks/Man-in-the-middle\\_attack](https://owasp.org/www-community/attacks/Man-in-the-middle_attack)

OWASP Foundation. (n.d.). Transport Layer Protection Cheat Sheet. OWASP Cheat Sheet Series.  
[https://cheatsheetseries.owasp.org/cheatsheets/Transport\\_Layer\\_Protection\\_Cheat\\_Sheet.html](https://cheatsheetseries.owasp.org/cheatsheets/Transport_Layer_Protection_Cheat_Sheet.html)